

SIMATS ENGINEERING

ASSESSMENT TOOL III – PENETRATION TESTING TASK

Course Code: ITA1412

Course Name: Ethical Hacking

Course Outcome: CO3 – Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities.

Duration: 90 Minutes

Total Marks: 50

Name: Reddy Dorniya

Reg No: 192372061

QUESTION 1 – THEHARVESTER RECONNAISSANCE

Aim

To perform external reconnaissance against the authorized domain **tesla.com** using the **theHarvester** tool and identify publicly available information such as email addresses, subdomains, hostnames, IP addresses, URLs, and other infrastructure-related information.

Tool Used

theHarvester

Target

Authorized Domain: tesla.com

Objective

The main objective of this activity is to understand how much information about an organization's external infrastructure can be collected from publicly available sources without directly attacking the target systems.

Procedure

TheHarvester was used to collect publicly available information related to the target domain. The tool searches different public data sources and attempts to identify information such as:

- Email addresses
- Subdomains
- Hostnames
- IP addresses
- URLs
- Publicly indexed infrastructure information

The reconnaissance was performed only against the authorized domain.

Command Used

theHarvester -d tesla.com -b all

If the installed version requires a specific data source, an appropriate supported source can be used instead.

```
kali@kali: ~
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~$ theHarvester -h
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* theHarvester 4.10.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*****
usage: theHarvester [-h] -d DOMAIN [-l LIMIT] [-s START] [-p] [-s] [--screenshot SCREENSHOT] [-e DNS_SERVER] [-t]
                  [-r [DNS_RESOLVE]] [-n] [-c] [-f FILENAME] [-w WORDLIST] [-a] [-q] [-b SOURCE]

theHarvester is used to gather open source intelligence (OSINT) on a company or domain.

options:
  -h, --help                show this help message and exit
  -d, --domain DOMAIN        Company name or domain to search.
  -l, --limit LIMIT          Limit the number of search results, default=500.
  -s, --start START          Start with result number X, default=0.
  -p, --proxies              Use proxies for requests, enter proxies in proxies.yaml.
  -s, --shodan               Use Shodan to query discovered hosts.
  --screenshot SCREENSHOT    Take screenshots of resolved domains specify output directory: --screenshot output_directory
  -e, --dns-server DNS_SERVER DNS server to use for lookup.
  -t, --take-over            Check for takeovers.
  -r, --dns-resolve [DNS_RESOLVE] Perform DNS resolution on subdomains with a resolver list or passed in resolvers, default False.
  -n, --dns-lookup           Enable DNS server lookup, default False.
  -c, --dns-brute            Perform a DNS brute force on the domain.
  -f, --filename FILENAME    Save the results to an XML and JSON file.
  -w, --wordlist WORDLIST    Specify a wordlist for API endpoint scanning.
  -a, --api-scan             Scan for API endpoints.
  -q, --quiet                Suppress missing API key warnings and reading the api-keys file.
  -b, --source SOURCE        baidu, bevigil, bitbucket, brave, bufferoverrun, builtwith, censys, certspotter, chaos, commoncrawl,
                             criminalip, crtsh, dehashed, dnsdumpster, duckduckgo, fofa, fullhunt, github-code, gitlab,
                             hackertarget, haveibeenpwned, hudsonrock, hunter, hunterhow, intelx, leakix, leaklookup, netlas,
                             onyphe, otx, pentesttools, projectdiscovery, rapiddns, robtex, rocketreach, securityscorecard,
                             securitytrails, shodan, subdomaincenter, subdomainfinder99, thc, threatcrowd, tomba, urlscan,
                             venacius, virustotal, waybackarchive, whoisxml, windvane, yahoo, zoomeye
```

```
kali@kali: ~
Session Actions Edit View Help
(kali@kali)~$ theHarvester -d tesla.com -b bing
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* theHarvester 4.10.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*****
The following engines are not supported: {'bing'}

[!] Invalid source.

(kali@kali)~$ theHarvester -d tesla.com -b duckduckgo
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* theHarvester 4.10.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*****

[*] Target: tesla.com
[*] Searching Duckduckgo.
[*] No IPs found.
[*] No emails found.
```

```
Session Actions Edit View Help
kali@kali: ~
--(kali@kali)~--
$ theHarvester -d tesla.com -b all -f tesla_report
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
theHarvester
theHarvester 4.10.1
Coded by Christian Martorella
Edge-Security Research
cmartorella@edge-security.com
*****

*) Target: tesla.com

Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process bevigil search for word: 'tesla.com'
Error Message:
[] Missing API key for bevigil.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml

[] Missing API key for Bitbucket.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process bufferoverrun search for word: 'tesla.com'
Error Message:
[] Missing API key for bufferoverrun.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to perform BuiltWith search for word: 'tesla.com'
Missing Key Error occurred in builtwith:
[] Missing API key for BuiltWith.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process brave search for word: 'tesla.com'
Error Message:
[] Missing API key for Brave Search.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Censys API key is missing or invalid:
[] Missing API key for Censys ID and/or Secret.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Missing key error occurred in criminalip:
[] Missing API key for criminalip.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Missing Key error occurred in dehashed:
[] Missing API key for Dehashed.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
```

Observations

The reconnaissance process demonstrated that publicly available sources can reveal useful information about an organization's external attack surface. The collected information may include domain-related hostnames, subdomains, email addresses, URLs, and IP addresses.

Security Analysis

Publicly available information can contribute significantly to an organization's external attack surface. Employee email addresses may potentially be used for phishing or social-engineering attempts. Subdomains can expose additional web applications, development systems, portals, APIs, or externally hosted services.

Hostnames and IP addresses may provide an attacker with information about the organization's naming conventions and infrastructure. When combined with information from DNS enumeration, search engines, certificate transparency records, and service scanning, individual pieces of publicly available information can provide a more complete picture of the target environment.

Risks Identified

1. Excessive public disclosure of employee information.
2. Unnecessary or forgotten subdomains.
3. Exposure of externally hosted services.
4. Disclosure of infrastructure naming conventions.
5. Increased possibility of targeted phishing and social engineering.
6. Increased external attack-surface visibility.

Recommended Security Controls

- Regularly review publicly exposed domains and subdomains.
- Remove unused or unnecessary DNS records.
- Minimize unnecessary disclosure of employee information.
- Maintain an updated external asset inventory.
- Monitor certificate transparency and public search results.
- Apply appropriate access controls to externally accessible services.
- Conduct periodic external reconnaissance from a defensive perspective.

Conclusion

TheHarvester demonstrated that significant information about an organization can potentially be collected without directly exploiting its systems. Publicly available information such as email addresses, subdomains, hostnames, IP addresses, and URLs can assist an attacker during reconnaissance. Organizations should therefore continuously monitor their public attack surface and minimize unnecessary information disclosure.

QUESTION 2 – NIKTO WEB SERVER ASSESSMENT

Aim

To assess the authorized web application **testphp.vulnweb.com** using **Nikto** and identify potentially exposed files, directories, insecure HTTP methods, server configuration weaknesses, information disclosure, outdated components, and other potential security issues.

Tool Used

Nikto

Target

testphp.vulnweb.com

Objective

The objective is to identify weaknesses in the web server configuration and determine what information is unnecessarily exposed to external users.

Procedure

Nikto was used to perform a web-server security assessment. The tool checks for common server configuration problems, dangerous files, exposed resources, outdated components, HTTP methods, and information disclosure.

Command Used

```
nikto -h http://testphp.vulnweb.com
```



```
kali@kali: ~
Session Actions Edit View Help
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_sitefiles
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Site Files" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_options
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "HTTP Options" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_cookies
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "HTTP Cookie Internal IP" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_ms10_070
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "ms10-070 Check" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_siebel
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Siebel Checks" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_dictionary_attack
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Dictionary attack" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_fileops
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "File Operations" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_negotiate
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Negotiate" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_report_xml
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "XML reports (v2)" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_outdated
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Outdated" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_robots
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Robots" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_core
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_multiple_index
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Multiple Index" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_auth
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Test Authentication" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_msgs
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Server Messages" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_tests
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Nikto Tests" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_cgi
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "CGI" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_paths
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Path Search" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_report_text
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Text reports" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_report_sqlg
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Generic SQL reports" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_apacheusers
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Apache Users" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Initializing plugin nikto_put_del_test
V:Mon Aug 10 05:17:34 2026 [Init] -- Loaded "Put/Delete test" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] -- Getting targets
V:Mon Aug 10 05:17:34 2026 [Reports] -- Opening reports (none)
V:Mon Aug 10 05:17:35 2026 [Init] -- 7232 server checks loaded
V:Mon Aug 10 05:17:35 2026 [Plugins] -- Running start for "HTTP Headers" plugin
V:Mon Aug 10 05:17:35 2026 [Plugins] -- Running start for "Favicon" plugin
V:Mon Aug 10 05:17:35 2026 [Plugins] -- Running start for "Content Search" plugin
V:Mon Aug 10 05:17:35 2026 [Plugins] -- Running start for "Test Authentication" plugin
V:Mon Aug 10 05:17:35 2026 [CheckSSL] -- Checking for HTTP on testphp.vulnweb.com:80, using GET
```

Potential Impact

Possible impacts include:

- Information disclosure.
- Identification of server technologies.
- Discovery of sensitive files.
- Increased attack surface.
- Potential exploitation of outdated software.
- Unauthorized access if dangerous resources are exposed.

Recommended Remediation

1. Remove unnecessary files and directories from the web server.
2. Disable directory listing where it is not required.
3. Disable unnecessary HTTP methods.
4. Keep server and application components updated.
5. Minimize unnecessary server-version disclosure.
6. Review web-server configuration regularly.
7. Restrict access to administrative and sensitive resources.
8. Perform regular vulnerability assessments.

Remediation Validation

After applying remediation, the organization should repeat the Nikto assessment and manually verify the previously identified findings. The affected files, directories, HTTP methods, and configuration settings should be checked to ensure that the exposure has been removed.

Conclusion

Nikto provides useful information about potential weaknesses in web-server configuration and exposed resources. The assessment demonstrates the importance of securely configuring web servers, limiting information disclosure, removing unnecessary resources, and maintaining updated software.

QUESTION 3 – DNS ENUMERATION USING DIG

Aim

To perform DNS enumeration against the authorized domain **zonetransfer.me** using the **Dig** utility and identify DNS records, authoritative name servers, and whether an unauthorized DNS zone transfer can be requested.

Tool Used

Dig

Target

zonetransfer.me

Objective

The objective is to understand what information DNS records reveal about an organization's infrastructure and determine whether unrestricted AXFR access is available.

Procedure

Different DNS queries were performed to identify important DNS records.

A Record

```
dig zonetransfer.me A
```

AAAA Record

```
dig zonetransfer.me AAAA
```

MX Record

```
dig zonetransfer.me MX
```

NS Record

```
dig zonetransfer.me NS
```

CNAME Record

```
dig zonetransfer.me CNAME
```

TXT Record

dig zonetransfer.me TXT

SOA Record

dig zonetransfer.me SOA

ANY Query

dig zonetransfer.me ANY

Zone Transfer Test

First, the authoritative name servers should be identified. Then an AXFR request can be tested against the authorized test domain.

dig AXFR zonetransfer.me @<authoritative-server>

Replace <authoritative-server> with the actual authoritative server discovered from the NS query.

```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
--(kali@kali)~--
$ dig <
dig 9.20.23-1-Debian
--(kali@kali)~--
$ dig zonetransfer.me A
;<>> Dig 9.20.23-1-Debian <>> zonetransfer.me A
;; global options: +cmd
;; Got answer:
;;->HEADER-- opcode: QUERY, status: FORMERR, id: 19481
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: d6e2133144133512 (echoed)
;; QUESTION SECTION:
;zonetransfer.me.      IN      A

;; Query time: 8 msec
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
;; WHEN: Mon Aug 10 05:20:36 EDT 2026
;; MSG SIZE rcvd: 56

--(kali@kali)~--
$ dig zonetransfer.me AAAA
;<>> Dig 9.20.23-1-Debian <>> zonetransfer.me AAAA
;; global options: +cmd
;; Got answer:
;;->HEADER-- opcode: QUERY, status: FORMERR, id: 7394
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: 6686ad9886a4162a (echoed)
;; QUESTION SECTION:
;zonetransfer.me.      IN      AAAA

;; Query time: 296 msec
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
;; WHEN: Mon Aug 10 05:20:43 EDT 2026
;; MSG SIZE rcvd: 56

--(kali@kali)~--
$ dig zonetransfer.me MX
```

```
kali@kali ~
Session Actions Edit View Help

;<>> Dig 9.20.23-1-Debian <>> zonetransfer.me MX
;; global options: +cmd
;; Got answer:
;;->HEADER-- opcode: QUERY, status: FORMERR, id: 36525
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: edd84a0b1b0807e3 (echoed)
;; QUESTION SECTION:
;zonetransfer.me.      IN      MX

;; Query time: 24 msec
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
;; WHEN: Mon Aug 10 05:20:55 EDT 2026
;; MSG SIZE rcvd: 56

--(kali@kali)~--
$ dig zonetransfer.me NS
;<>> Dig 9.20.23-1-Debian <>> zonetransfer.me NS
;; global options: +cmd
;; Got answer:
;;->HEADER-- opcode: QUERY, status: FORMERR, id: 48016
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: 28e75b60650e7b49 (echoed)
;; QUESTION SECTION:
;zonetransfer.me.      IN      NS

;; Query time: 52 msec
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
;; WHEN: Mon Aug 10 05:21:02 EDT 2026
;; MSG SIZE rcvd: 56
```

DNS records provide valuable information about an organization's infrastructure. A records can reveal IPv4 addresses, while AAAA records can reveal IPv6 addresses. MX records identify mail infrastructure, and NS records identify authoritative DNS servers.

A successful unauthorized AXFR request can be particularly significant because it may disclose a large number of DNS records at once. This could reveal internal naming conventions, hostnames, server relationships, and additional infrastructure that may otherwise be difficult to discover.

```
kali@kali:~$ cat /dev/null | nc -l -v --port 1337 &
Session Actions Edit View Help
C GEBALVFFWPHBQJULIMUJVdGtEzDnHqHCeEDORCKjnsGVfFbzLwD7oScCbchbcgclzvYFUENImBuTUMPAFLZrFoTvbyRyMWRDeDO ZskkURDI
UBmPQRWPMKSMNMBIWI/PIS9AGevygdcxsl3bbXTATXAN DPKTLFeWhCFc+Bgifbebvdyozfzm/VSymskdMcglSbuYVibebACAdAAATAstkbqhkiOgw
ASXZKLVIIFEFBCIPMMVDylpwlpwg-CMGTo UBVFQZFzbApvg-VBFSLBPf8Agf/MaelneSVShnuXotdbPPAawQMWS HJveIEBoAACAEAAATAstkbqhkiOgw
BAQSFAQAACAQEAOEQAPdvTPVZ?T tkkgCGAMybMbTZBJdu1UnsBon-K7KNrnGoBrVAtMd-XwOb-2UgvYIOB ubKOLGXOGVYoIMWvrITINBRKSsnIsSeaktzesNGW
IVABvUuyLiCdlt OgnktaksTeZmlInsdgtetADnSGZCMPOgfPrGdlgzPCpBaIdlyIp SapunJKbal-vYruZvwvywyKTUXMSVVIIIZIBogdfPB9PNWWII
IC AdmfIfzi-zVtWMStzsksfrMLvtbZhwQvbnSRilccDG3ysgClCYLY meAMNMzIDOMAcQtTuZRdeZLIffSmSOgyJJfyCyNetPhKaZeChVCyrME
zonetransfer.me.      300    IN     HINFO   "Casio fx-700G" "Windows XP"
acme-challenge.zonetransfer.me. 301    IN     TXT     "0da5bHu3jcxsvyv7pApQGCUSSGOgcggpfPEXiZ"
sip.tz.zonetransfer.me. 14000   IN     SRV     0 5 600 zonetransfer.me..
14000   IN     PTR     www.zonetransfer.me.
asfdbushtnds.zonetransfer.me. 7900    IN     AFSDB   asfdbox.zonetransfer.me.
asfdbox.zonetransfer.me.       7200   IN     A        127.0.0.1
asfdvolume.zonetransfer.me.    7800   IN     AFSDB   1 asfdbox.zonetransfer.me.
canberra-office.zonetransfer.me. 7200   IN     A        202.141.21.230
canberra.zonetransfer.me.      300    IN     TXT     " ! !"
contact.zonetransfer.me. 2592000 IN     TXT     "Remember to call or email Pippa on +44 123 4567890 or pippad@zonetransfer.me when making DNS changes"
dc-office.zonetransfer.me. 7200    IN     A        143.228.181.132
deadbeat.zonetransfer.me. 7201    IN     AAAA     deadbeat.f
drz.zonetransfer.me.          7200   IN     LOC      36 56.558 N 1 38 33.526 W 0.00m In 1000nm 10m
dzc.zonetransfer.me.         7200   IN     TXT      "Abcfefo"
email.zonetransfer.me.        2222   IN     NAPTR    " s ?" "Edu@mail" "" email.zonetransfer.me.zonetransfer.me.
info.zonetransfer.me.         7200   IN     A        74.125.206.200
hello.zonetransfer.me.        7200   IN     TXT      "Hi to Josh and all his class"
home.zonetransfer.me.         7200   IN     A        127.0.0.1
honeypot.zonetransfer.me.     7200   IN     TXT      "Zonetransfer.me service provided by Robin Wood - robin@digi.ninja. See http://digi.ninja/projects/honeypots-for-more-info/"
internal.zonetransfer.me.     300    NS       intns1.zonetransfer.me.
internal.zonetransfer.me.     300    NS       intns2.zonetransfer.me.
intns1.zonetransfer.me.       300    IN       A        81.4.308.401
intns2.zonetransfer.me.       300    IN       A        5.196.185.110
office.zonetransfer.me.       7200   IN       A        4.23.39.254
ipwbactnow.org.zonetransfer.me. 7200   IN     AAAA     2081:67c:d6d1::c0011332
ipwbactnow.org.zonetransfer.me. 7200   IN     A        207.46.197.2
robinwood.zonetransfer.me.    302    IN       TXT      "Robin wood"
robinwood.zonetransfer.me.    302    IN       RP       robin.zonetransfer.me., robinwood.zonetransfer.me.
sip.zonetransfer.me.          3333   IN     NAPTR    " s ?" "Edu@sip" "!"; sip:customer-service@zonetransfer.me." ,
sqll.zonetransfer.me.         300    IN     TXT      "*" or 1-! -!"
ashock.zonetransfer.me.       7200   IN     TXT      "{ [ ] ; } : echo Shellshocked"
atking.robinhood.net.yodapoparhouse.com. 7200   IN     CNAME     atking.zonetransfer.me.
allcpportsofen.firewall.test.zonetransfer.me. 301    IN     A        127.0.0.1
testing.zonetransfer.me.      301    IN     CNAME     www.zonetransfer.me.
vpn.zonetransfer.me.          4000   IN     A        174.36.59.154
vpn.zonetransfer.me.          7200   IN     A        5.196.185.110
ssn.zonetransfer.me.          300    IN     TXT      "<script>alert('Ban')</script>"
zonetransfer.me.             7200   IN     SOA      nsztmt.digi.ninja.; robin.digi.ninja. 2019100801 172800 900 120960 3600
```

- Infrastructure information disclosure.
- Discovery of mail servers.
- Exposure of hostnames and service relationships.
- Easier external reconnaissance.
- Increased attack-surface visibility.
- Potential disclosure of internal or forgotten systems through an unrestricted zone transfer.

1. Restrict AXFR requests to authorized secondary DNS servers.
2. Disable unrestricted zone transfers.
3. Use appropriate DNS server access-control mechanisms.

4. Review DNS records periodically.
5. Remove obsolete DNS entries.
6. Monitor DNS configuration changes.
7. Avoid unnecessary sensitive information in public DNS records.

Remediation Validation

After applying DNS security controls, the AXFR request should be repeated from an unauthorized source. The transfer should be refused while legitimate secondary DNS servers should continue to function correctly.

Conclusion

The Dig utility provides an effective method for DNS enumeration. DNS records can reveal valuable infrastructure information that can assist attackers during reconnaissance. Properly restricting zone transfers and regularly reviewing DNS records can significantly reduce unnecessary information exposure.

QUESTION 4 – SMB/NETBIOS ENUMERATION USING ENUM4LINUX

Aim

To perform SMB and NetBIOS enumeration against the authorized Windows target **192.168.1.100** using **Enum4linux** and identify exposed users, groups, shares, domain/workgroup information, operating-system information, password-policy details, and other SMB configuration information.

Tool Used

Enum4linux

Target

192.168.1.100

Objective

The objective is to determine what information can be obtained from SMB and NetBIOS services before attempting any exploitation.

Procedure

Basic enumeration was performed using Enum4linux.

Full Enumeration

```
enum4linux -a 192.168.1.100
```

User Enumeration

```
enum4linux -U 192.168.1.100
```

Share Enumeration

```
enum4linux -S 192.168.1.100
```

Group Enumeration

enum4linux -G 192.168.1.100

Operating-System Information

enum4linux -o 192.168.1.100

Password Policy

enum4linux -P 192.168.1.100

NetBIOS Information

enum4linux -n 192.168.1.100

```

kali@kali: ~
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
[kali@kali]~$
[kali@kali]~$ enum4linux -h
enum4linux v0.9.1 (http://labs.portcullis.co.uk/application/enum4linux/)
Copyright (C) 2011 Mark Lowe (mrl@portcullis-security.com)

Simple wrapper around the tools in the samba package to provide similar
functionality to enum.exe (formerly from www.bindview.com). Some additional
features such as RID cycling have also been added for convenience.

Usage: ./enum4linux.pl [options] ip

Options are (like "enum"):
-U get userlist
-M get machine list*
-S get shrelist
-P get password policy information
-G get group and member list
-d be detailed, applies to -U and -S
-u user specify username to use (default "")
-p pass specify password to use (default "")

The following options from enum.exe aren't implemented: -L, -N, -D, -f

Additional options:
-a Do all simple enumeration (-U -S -G -P -o -n -i).
  This option is enabled if you don't provide any other options.
-h Display this help message and exit
-r enumerate users via RID cycling
-R range RID ranges to enumerate (default: 500-550,1000-1050, implies -r)
-k n Keep searching RIDs until n consecutive RIDs don't correspond to
  a username. Implies RID range ends at 999999. Useful
  against DCs.
-l Get some (limited) info via LDAP 389/TCP (for DCs only)
-s file brute force guessing for share names
-k user User(s) that exists on remote system (default: administrator,guest,krbtgt,domain admins,root,bin,none)
  Used to get sid with "lookupsid known_username"
  Use commas to try several users: "-k admin,user1,user2"
-o Get OS information
-l Get printer information
-w wkg Specify workgroup manually (usually found automatically)
-n Do an nslookup (similar to nbtstat)
-v Verbose. Shows full commands being run (net, rpcclient, etc.)
-A Aggressive. Do write checks on shares etc

```

```

kali@kali: ~
Session Actions Edit View Help

NB: Samba servers often seem to have RIDs in the range 3000-3050.

Dependency info: You will need to have the samba package installed as this
script is basically just a wrapper around rpcclient, net, nslookup and
smbclient. Polenum from http://labs.portcullis.co.uk/application/polenum/
is required to get Password Policy info.

[kali@kali]~$
[kali@kali]~$ enum4linux 192.168.1.100
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Aug 11 07:23:18 2026

===== ( Target Information ) =====
Target ..... 192.168.1.100
RID Range ..... 500-550,1000-1050
Username ..... 
Password ..... 
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.1.100 ) =====
[!] Can't find workgroup/domain

===== ( Nbtstat Information for 192.168.1.100 ) =====
Looking up status of 192.168.1.100
No reply from 192.168.1.100

===== ( Session Check on 192.168.1.100 ) =====

[!] Server doesn't allow session using username: '', password: ''. Skipping remainder of tests.

```

```
(kali@kali)-[~]
└─$ enum4linux -u 192.168.1.100
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Aug 11 07:24:32 2026

----- ( Target Information ) -----
Target ..... 192.168.1.100
RID Range ..... 500-550,1000-1050
Username ..... ""
Password ..... ""
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

----- ( Enumerating Workgroup/Domain on 192.168.1.100 ) -----

[E] Can't find workgroup/domain

----- ( Session Check on 192.168.1.100 ) -----

[E] Server doesn't allow session using username: "", password: "", aborting remainder of tests.

(kali@kali)-[~]
└─$ enum4linux -u 192.168.1.100
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Aug 11 07:24:59 2026

----- ( Target Information ) -----
```

Security Analysis

SMB and NetBIOS enumeration can reveal useful information about a Windows environment. Usernames can potentially help attackers identify accounts that may become targets for credential attacks. Group information can help determine relationships between accounts and privileges.

Accessible SMB shares may expose files or resources to unauthorized users if permissions are not correctly configured. Domain and workgroup information can help an attacker understand the structure of the Windows environment.

Password-policy information may also provide information about account security requirements and can be useful when assessing the strength of authentication controls.

Security Risks

1. User-account information disclosure.
2. Excessively accessible SMB shares.
3. Weak access controls.
4. Exposure of domain/workgroup information.
5. Information useful for credential attacks.
6. Increased risk of lateral movement if credentials are compromised.
7. Potential privilege-related information disclosure.

Recommended Controls

- Disable anonymous or null-session enumeration where unnecessary.
- Apply least-privilege access to SMB shares.
- Remove unnecessary shared folders.
- Use strong authentication policies.
- Apply account lockout and authentication protections where appropriate.
- Keep Windows systems and SMB components patched.
- Restrict SMB access through network segmentation and firewall rules.

- Monitor unusual SMB authentication and access activity.
- Review user and group permissions regularly.

Remediation Validation

After implementing security controls, Enum4linux should be run again to confirm that unnecessary user, group, share, and configuration information is no longer exposed. Share permissions should also be manually verified using authorized accounts.

Conclusion

Enum4linux demonstrated how SMB and NetBIOS services can disclose valuable information about a Windows environment. Limiting unnecessary enumeration, securing shared resources, applying least privilege, maintaining strong authentication, and restricting SMB network access can reduce the risk of unauthorized access and lateral movement.

QUESTION 5 – SERVICE BANNER ENUMERATION USING NETCAT

Aim

To use **Netcat (nc)** against the authorized target **scanme.nmap.org** to connect to accessible TCP services and collect service responses and banner information.

Tool Used

Netcat (nc)

Target

scanme.nmap.org

Objective

The objective is to determine what technical information is voluntarily disclosed by externally accessible services and evaluate how such information could assist service fingerprinting.

Procedure

First, the target hostname was resolved and accessible services were identified within the authorized scope. Netcat was then used to connect to appropriate TCP services.

Basic Netcat Connection

```
nc -v scanme.nmap.org 80
```

The -v option provides verbose connection information.

After establishing the connection to HTTP, the following request can be entered:

```
GET / HTTP/1.1
```

```
Host: scanme.nmap.org
```

```
Connection: close
```

The blank line at the end is required to terminate the HTTP request.

```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
[kali@kali]~$ nc -h
[1.10-50.1]
connect to somewhere: nc [-options] hostname port[s] [ports] ...
listen for inbound: nc -l -p port [-options] [hostname] [port]
options:
-c shell commands      as "-e"; use /bin/sh to exec [dangerous!!]
-e filename            program to exec after connect [dangerous!!]
-b                    allow broadcasts
-g gateway             source-routing hop point[s], up to 8
-G num                source-routing pointer: 4, 8, 12, ...
-h                    this cruff
-i secs               delay interval for lines sent, ports scanned
-k                    set keepalive option on socket
-l                    listen mode, for inbound connects
-n                    numeric-only IP addresses, no DNS
-o file               hex dump of traffic
-p port               local port number
-r                    randomize local and remote ports
-q secs               quit after EOF on stdin and delay of secs
-s addr               local source address
-T tos                set Type Of Service
-t                    answer TELNET negotiation
-U                    UDP mode
-v                    verbose [use twice to be more verbose]
-w secs               timeout for connects and final net reads
-C                    Send CRLF as line-ending
-Z                    zero-I/O mode [used for scanning]
port numbers can be individual or ranges: lo-hi [inclusive];
hyphens in port names must be backslash escaped (e.g. 'ftp-data').

[kali@kali]~$ nmap scanme.nmap.org
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-11 07:33 -0400
Failed to resolve "scanme.nmap.org".
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 4.39 seconds

[kali@kali]~$ nc scanme.nmap.org 80
scanme.nmap.org: forward host lookup failed: Host name lookup failure : Resource temporarily unavailable

[kali@kali]~$ nc scanme.nmap.org 443
scanme.nmap.org: forward host lookup failed: Host name lookup failure : Resource temporarily unavailable

[kali@kali]~$ nc scanme.nmap.org 22
scanme.nmap.org: forward host lookup failed: Host name lookup failure : Resource temporarily unavailable

[kali@kali]~$ printf "HEAD / HTTP/1.1\r\nHost: scanme.nmap.org\r\n\r\n" | nc scanme.nmap.org 80 > http_banner.txt

[kali@kali]~$ cat http_banner.txt
HTTP/1.1 200 OK
Date: Tue, 11 Aug 2026 11:37:40 GMT
Server: Apache/2.4.7 (Ubuntu)
Accept-Ranges: bytes
Vary: Accept-Encoding
Content-Type: text/html
```

Security Analysis

Service banners and HTTP response headers can provide useful information about the technologies running on a server. A service may disclose its software name, protocol, version, or implementation details.

Accurate service fingerprinting allows an attacker to narrow down potential attack techniques. If a specific software version is disclosed, it may be correlated with publicly known vulnerabilities. However, version disclosure alone does not prove that a vulnerability exists.

Additional validation is required to determine whether the identified software version is actually vulnerable and whether exploitation is possible.

Potential Security Impact

Service-banner exposure may:

- Help attackers identify technologies.
- Assist in software fingerprinting.
- Reveal server implementation details.
- Help attackers correlate software versions with known vulnerabilities.
- Make subsequent attacks more targeted.

Recommended Security Controls

1. Minimize unnecessary service-banner information.
2. Keep externally exposed software updated.
3. Disable unnecessary services.
4. Restrict publicly accessible ports.
5. Configure HTTP response headers appropriately.
6. Use firewalls and network access controls.
7. Periodically review externally exposed services.
8. Monitor logs for unusual connection and scanning activity.

Remediation Validation

After making configuration changes, the service should be tested again using Netcat or another approved enumeration tool. The organization should verify that unnecessary banner information has been reduced while legitimate service functionality remains unaffected.

Conclusion

Netcat is a simple but effective tool for examining TCP services and observing their responses. Service banners and HTTP headers can provide useful fingerprinting information to attackers. Although banner disclosure is not necessarily a direct vulnerability, reducing unnecessary information exposure and maintaining updated services can make reconnaissance and subsequent attacks more difficult.

OVERALL ASSESSMENT SUMMARY

The five practical exercises demonstrated different stages of penetration-testing reconnaissance and enumeration.

TheHarvester was used to collect publicly available information about an external domain. Nikto was used to identify potential web-server configuration weaknesses and exposed resources. Dig was used to analyze DNS records and assess zone-transfer exposure. Enum4linux was used to enumerate SMB and NetBIOS information from a Windows target. Netcat was used to interact with TCP services and observe service banners and responses.

These activities demonstrate that attackers can gather substantial information before attempting exploitation. Information from different reconnaissance techniques can also be correlated. For example, a discovered hostname can be resolved through DNS, its IP address can be scanned for open services, and service banners can then be analyzed for technology and version information.

Common Security Recommendations

- Maintain an accurate inventory of externally exposed assets.
- Remove unnecessary public-facing services.
- Regularly review DNS records and subdomains.

- Restrict DNS zone transfers.
- Secure SMB services and shared resources.
- Disable unnecessary network services.
- Keep operating systems, web servers, and applications patched.
- Minimize unnecessary version and banner disclosure.
- Apply least-privilege access controls.
- Use network segmentation and firewall rules.
- Perform periodic vulnerability assessments.
- Monitor external attack-surface changes.
- Validate security fixes through repeat testing.

Final Conclusion

The assessment demonstrated the importance of reconnaissance and enumeration in penetration testing. Publicly available information, DNS records, web-server responses, SMB enumeration, and service banners can collectively provide an attacker with valuable information about an organization's infrastructure.

No individual reconnaissance finding should automatically be considered a confirmed vulnerability. Findings must be validated and their actual security impact determined. Organizations can reduce their attack surface by minimizing unnecessary information disclosure, securing externally accessible services, enforcing strong access controls, applying patches, restricting unnecessary network access, and conducting regular security assessments.

STUDENT DECLARATION

I, Reddy Dorniya (Reg No: 192372061), certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the Student: _____

Name: Reddy Dorniya

Register Number: 192372061

Final Word-document order

Use this order in your document:

1. **Cover / Assessment Details**
2. **Question 1 – theHarvester**
3. Q1 screenshots + observations
4. **Question 2 – Nikto**

5. Q2 screenshots + observations
6. **Question 3 – Dig**
7. Q3 screenshots + observations
8. **Question 4 – Enum4linux**
9. Q4 screenshots + observations
10. **Question 5 – Netcat**
11. Q5 screenshots + observations
12. **Overall Assessment Summary**
13. **Final Conclusion**
14. **Student Declaration & Signature**

Important: Replace every **[Actual result]** with the output you actually obtained. This makes the report consistent with your practical screenshots and avoids claiming findings that weren't observed.